

Professional Penetration Test Report

By: Shawn Roth

Cybr320 – Ethical Hacking

Winter 2026

Contents

Executive Summary:	3
Methodology and Scope	4
Findings and Evidence:	6
Recommendations and Roadmap:.....	12
Conclusion	14
Appendix: Personal Narrative Thread	17
Appendix: Professional Growth Addendum	17

Executive Summary:

North Cascades Community College (NC3) is vulnerable to insider threats in the form of students. During this penetration test we simulated the role of a frustrated student, facing financial and academic stress. We have crafted a student persona, an IT student named Kevin Neal. Kevin has access to campus Wi-Fi, a personal laptop, free tools and the system enumeration skills he's learned throughout his coursework. Kevin was successful in his attempt to access staff systems, install a backdoor and exfiltrate data.

This assessment determined that NC3 systems have severe vulnerabilities that could harm its students, staff and college reputation.

EternalBlue SMB Vulnerability: The attacker performed a port scan and seen that port 445 was open and running a version of SMB that was still vulnerable to EternalBlue, a remote code execution vulnerability. This vulnerability can be used to deploy ransomware across the campus network (Microsoft 2017). This could lead to significant damage for NC3 including encryption of student records, financial information, grades etc. You may even face legal troubles, and it could have negative impact on your college reputation.

Netcat backdoor and connection to external IP's: Kevin was also able to successfully spawn a reverse shell on a faculty laptop. There was clear connection between the staff laptop and an external IP address on port 443. The connection was hidden well, blending in as normal web browsing traffic (Rossouw 2026).

Lack of Network Segmentation: Due to the lack of network segmentation Kevin was able to gain access to the LMS from the faculty laptop, possibly giving him access to information not intended for students but rather for staff. Also, the LMS proxy server is running on port 8080

which uses unencrypted http protocol, showing traffic in plain text. Since the network isn't separated, a student on the NC3 wireless Wi-Fi could run a sniffer and see the plain text traffic possibly seeing staff login credentials.

Overall, the NC3 network is poorly configured, and has poor company policies in place to secure the network. One of the scans shows that a faculty laptop had a process called Dropbox, a personal cloud file sharing service which could be targeted by the attacker for data exfiltration. The student was able to gain remote access to the faculty computer, establish persistence and connection back to hit host device.

Methodology and Scope

To perform a penetration test to help NC3 secure their network we must first understand who we are most vulnerable to and how they can attack us. In this case it would be an inside threat actor, a student named Kevin Neal. Kevin is a second year IT student enrolled in cyber security and computer science classes. Throughout his coursework he has developed the basic skills required to enumerate and exploit a system. His frustrations have been building, a drop in his GPA has resulted in a decrease in the amount of financial aid he has been receiving. Given that he has access to the school public WIFI he decides that this would be a good place to look for vulnerabilities to try to unethically change his grades and increase his GPA.

Kevin has a good understanding of how the school network operates and is familiar with the web applications and services that NC3 uses. He has the knowledge to be able to run sniffer tools like Wireshark on the network to look for unencrypted traffic, port scanning tools like Nmap, and hacking tools like Metasploit.

Kevin is far less sophisticated than someone like a nation state actor, but he can still cause damage and gain unauthorized access to systems given his current skill set. He will be able to look for vulnerabilities due to bad configuration and look to exploit these vulnerabilities.

The anchor system that I will be focusing on is the public facing student portal web application (The LMS). Students often use this portal to register for classes, make tuition payments, financial aid information, access grades, transcripts, etc. This application holds a plethora of sensitive student information making it a prime target for a frustrated student. At my college institution we use a similar system called CTClink, this is our student portal. We can visit this application to manage all our classes and view financial aid information, so I know firsthand that these portals contain sensitive data. A student with malicious intent would focus on systems that contain this type of data, a student portal that is accessed through a web browser without secured connection, MFA, VPN, would become a primary target for enumeration.

The Scope of this penetration test is going to include the LMS proxy, a faculty workstation, campus Wi-Fi, and our own personal laptop. Out-of-scope targets are going to include student devices, other staff workstations and IOT devices. Anything that isn't named as being part of the scope is going to be off limits during the test.

To ensure that we do not interrupt NC3's operations, we will have a time window during the least busy hours. This will include weekends (Saturday and Sunday) when campus is closed, while allocating 6-8 hours for each target within the scope. If additional time is needed, we will be in contact with the person in charge. Time frame can very depend on the complexity of the network and additional time will be needed to draft and send our final report. The entire process should take no longer than 3 weeks. (Kaplan, C. 2024)

The methodology followed a standard penetration testing approach: initial threat modeling and persona development, host and web enumeration using Nmap scans, vulnerability scanning and malware analysis, packet capture analysis to observe real traffic, and defensive tool mapping.

Findings and Evidence:

Port scan/system enumeration -

After looking at the Nmap scan results we were able to determine that the following ports are open. We will give a list of the services running on each port, along with what they are used for and how an attacker might target each port.

Port 135 – Port 135 is running Microsoft Remote Procedure Call service. When you have client computers and servers that all need to remotely connect to each other, they use an endpoint mapper service. This is the port they use to run that service on. Given the skill level of the attacker, they will likely look for vulnerabilities in the RPC service to try to execute remote commands on a system. (Cohen C. 2024)

Port 139 – Port 139 is running the Netbios-snn service. This port and service are typically used for printer and file sharing on windows networks. This service typically works alongside port 445 and the SMB protocol to allow file and network resource sharing. If port 139 is open to the public an attacker can use the nbstat to help them create a footprint for their attack. The command will give them a detailed list of host names and IP address to help plan their attack. (Cohen C. 2023)

Port 445 – This port is running the Microsoft-ds service. This is the Microsoft Directory service running on this port using the SMB protocol to allow file and resource sharing within the network. This is a known targeted port for attackers, making it likely target for this type of attack

persona. Given the skill of this attacker, they will likely run scans on the port and service to see what service and version we are running and check for unpatched vulnerabilities.

(SecurityScorecard 2025)

Port 3389 – This port is running the ms-wbt-server service on port 3389 using the Remote Desktop Protocol. This port and service is used for employees to have remote access to internal resources. An attacker of this skill level may attempt to brute force attacks to be able to gain unauthorized access to the network. (Lee B. 2025)

Port 5357 – This port is running an http service that allows Web Service for Discovery to locate and discover devices on the network. A computer needs to be able to find devices such as printers, scanners and other IoT Devices on the network this is the port and service that is used. Being that this service is using http and not https that would mean the data isn't encrypted, an attacker would likely use a sniffer on the network to try to find plain text data that leaks things like usernames, passwords, print jobs, etc. (Jurić, L., Šikić, L., & Novak, M. 2026)

Port 5985 – This port runs a service called WinRM. This service and port are used to gain remote access to machines on the network. Without physically being at the machine, you can run commands on one machine from another. This port also uses http to communicate so the data is unencrypted which would be a likely target for attackers. An attacker would likely use known exploits on the WinRM service to try to run unauthorized commands or look for sensitive data leaked in a sniffer since it doesn't use https to communicate. (Jurić, L., Šikić, L., & Novak, M. 2025)

Port 8080- This port is running an Apache httpd service on a windows machine (win32). Based on the http header, this service is functioning as a proxy server for the NC3 faculty LMS.

This would become a likely target for our persona because it is the server for the staff learning management system. Our attacker would likely interact with the page and look for any login fields or pages that shouldn't be accessible to the public.

Vulnerability Evidence –

After seeing the nessus scan we see that the system has several vulnerabilities but the most notable are EternalBlue SMB Remote Code Execution (critical), No network level authentication required for RDP (High), SMB signing not required (Medium), Software Inventory Disclosure. I will go into further detail below about each vulnerability and provide brief description and remediation for each.

SMB remote code execution- The host support SMBv1 and is missing the MS17-010 security patch. This is a critical vulnerability that can be used for a remote attacker to send crafted packets to port 445 which can run arbitrary code on a machine, install applications, or deploy ransomware. This was the vulnerability responsible for the Wannacry attack, leaving you vulnerable to the same type of attack on NC3's network (BetaFred. 2017). An attacker could encrypt all your data and deploy ransomware across the entire campus. To remediate this vulnerability, you must deploy the Microsoft windows patches that are available to address this vulnerability, also disable SMBv1 and transition to SMBv2 or SMBv3 instead.

RDP not requiring network level authentication- Due to the lack of network level authentication during RDP sessions this leaves you susceptible to man in the middle attacks and session hijacking. An attacker could also use different tools to harvest credentials because no authentication is in place. To mitigate this, you must enable NLA in the RDP settings and only allow machines with this setting to access RDP. This will require a user to authenticate before

making any remote connection. Only allowing users on a VPN to be able to access RDP connections would also be a good way to mitigate this vulnerability.

SMB Signing Not Required- If a system has SMB signing disabled than an attacker could attempt an NTLM attack which essentially intercepts the authentication request and gives them a password hash. They then use another tool to decrypt that hash which would reveal a user's password. They can use this to gain unauthorized access to NC3's network and perform privilege escalation as well. The most efficient way to mitigate this vulnerability is by enabling SMB signing in group policies. (Butcher A. 2023)

Software Inventory Disclosure- When running the system scan, we were able to see which operating system the machine used, application and software details. These are details an attacker would look at while targeting NC3's infrastructure. If they see you are running a specific version of adobe that has known vulnerabilities, they can look to exploit. Also, the presence of something like Dropbox shows them what they are going to use to exfiltrate their data. Showing certain services and application versions is hard to mitigate during a scan, however you can always keep your applications up to date with the latest patches to ensure they aren't exploitable.

Evidence of compromise –

After analyzing the provided netstat and nessus data provided I have concluded that there are suspicious connections. Most of the processes align with normal use of a staff members laptop such as teams, and other normal windows processes. However, there are some activities that don't align such as, netcat, Dropbox, and python. Netcat is listening on port 1337 and is a common process used to establish persistence and execute remote code execution (Invicti 2026). This process also established outbound connections to external IP addresses. Python also shows

suspicious behavior because that means that there is an automated python script running in the background and it establishes connection to an external IP address. Dropbox is personal cloud storage used for filesharing which shouldn't be on a staff laptop. This can be used to exfiltrate data if the system is compromised. Another big concern is the established connection from termservice on port 3389 which is the RDP port indicating that there is a remote connection to an external IP address.

Given the data from the scan results I can confidently say that the laptop is compromised. The netcat process is a strong indicator of a backdoor because it is listening for connections on a common port used to establish reverse shells. Also, the RDP connection to an external IP address shows that someone may already have control of the laptop.

Packet Capture analysis of the penetration test –

Capture 1 SSH session established-

In this capture, I see a standard TCP 3-way handshake on port 22 (GeeksForGeeks 2025) along with packets of data that we can't see. The handshake is happening between a student computer and a faculty laptop. I don't know if this is legitimate activity because a student shouldn't be establishing an SSH session to a faculty laptop however, the session is established. From a defender's perspective this activity would look completely normal despite the session coming from a student laptop. From the attacker's perspective, this shows them that the student can establish an SSH session giving the student access to the command line interface of the faculty laptop (not good).

Capture 2 DNS resolution and Unencrypted HTTP-

Here I see a faculty laptop connecting to the DNS server then resolving the IP address 74.125.95.103 to google.com. This is then followed by a 3-way TCP handshake. This traffic looks legitimate, however, the traffic is happening on port 80 which uses the http protocol, so the traffic is unencrypted which is why we see google.com in plain text. As a defender, this is what we are looking at and it's exactly what we want to mitigate in our network. An attacker could use a sniffer on the network and filter http traffic potentially revealing login credentials and session cookies.

Capture 3 DNS resolution and HTTPS session.

Once again, I see the faculty laptop making a DNS resolution of an IP address on port 53 which is the DNS port. This resolves the IP address 209.85.225.104 to google once again but this time on port 443. Once they resolve the IP there is a 3-way handshake but this time the data is encrypted because they are on port 443 which uses the HTTPS protocol allowing for secure encrypted web browsing. This is what you like to see as far as web traffic for a defender, encrypted web browsing traffic. If an attacker ran a sniffer on the network these packets would be useless to them because nothing is in plain text like on port 80.

Capture 4 Internal HTTP traffic to LMS proxy.

In the capture there is an http connection on port 8080 between the faulty laptop and the LMS proxy server. Port 8080 is an alternative port to port 80, if I were a defender I would find this traffic troublesome because traffic to our LMS should be through a secure encrypted connection not through a port that uses the http protocol. An attacker would likely target this occurrence attempting to hijack sessions because the attacker will see Apache LMS Proxy and know that it's the Learning management system.

Capture 5 Port scan targeting NC3 Faculty laptop-

This traffic is starting to raise flags we see a student's laptop running a port scan on a faculty laptop, the given ports are 3389, 5985, 22, 8080, 445, 1337, 135, and 139. From a defender's point of view this raises concern a student is enumerating the faculty laptop by performing this port scan, also it comes from the same IP address that established the SSH connection in capture 1. From the attacker side they are running this scan to see which ports are open, if they see port 445 open they can now see if its vulnerable to remote code execution exploits like Eternal blue which the system is.

Capture 6 Outbound traffic to external IP-

In this capture we see an encrypted connection between the faculty laptop and IP address 162.247.241.14 on port 443. This is the same IP address we have seen in the netstat results that established a connection with the process ID nc.exe or netcat. Since port 1337 was listening the attacker created a listener on that port then made the connection through port 443 to blend in with normal web browser traffic. To a defender this connection looks different, see the connection on port 443 earlier in capture 2 they performed a DNS resolution then a handshake. Here you see no DNS resolution, just an established connection, this is not normal web traffic (Rossouw J. 2026). To an attacker, they have successfully spawned a reverse shell.

Recommendations and Roadmap:

Short Term Actions -

The first thing that needs to be done is to address the critical vulnerabilities that we detected. There are Microsoft patches available that address EternalBlue and can disable the SMBv1 on your entire network. This is a major vulnerability and was responsible for one of the biggest

cyber-attacks of all time (Archondakis A. 2026). Patching this vulnerability should be of the utmost importance to prevent an attack of the same magnitude on NC3. Next, I would enable Microsoft Windows Defender on all endpoint machines. The faculty laptop was easily exploited by the netcat backdoor meaning that the laptop was poorly configured and lacked any antivirus software that catches malicious software in real time. You can enable Windows Defender on all endpoint machines in the network through your group policy configuration page without having to visit each machine physically (Paulinbar. 2026)

Medium Term Actions –

This will take a little bit more time but the next step in hardening your network would be to implement network segmentation. The students, staff, and LMS proxy server should be on their own VLANs. If a particular machine is exploited this would prevent lateral movement from one VLAN to the next. For example, if someone was able to gain access to the LMS proxy server they wouldn't be able to access the internal resources of the staff VLAN (Cisco 2025). Also, I would implement more user authentication methods across logins for the SSH and RDP connections. Instead of using passwords to establish connections for SSH we need to change to public keys instead of passwords, this is much harder to brute force your way into (Cisco 2026). I would also make a firewall rule to not allow RDP connections from the student VLAN to the Staff VLAN. These connections should never have been allowed; a student shouldn't be able to establish either SSH or RDP connections to staff or faculty machines. Finally, the LMS proxy should not be running on port 8080 this uses the http protocol, so the traffic isn't secure or encrypted, change the server to run on port 443 so that it uses the https secure encrypted protocol. Along with the server, make a new firewall rule to not allow http traffic while browsing

but rather use https so that your connections are encrypted and not vulnerable to sniffers revealing plain text in the traffic packets.

Long Term Actions –

This is where we need to implement better company policies such as acceptable use policies. Users shouldn't be allowed to download apps as they please, such as Dropbox. Also implementing something like Threat locker to help implement a zero-trust policy and default denying any application that isn't in the allow list would help unwanted applications running on devices. Next, a training course for your employees is necessary. You must teach them about cyber security and the dangers of phishing, malicious downloads and unwanted software.

Conclusion

In conclusion, the NC3 network is poorly configured and had poor policies put into place. The presence of an application like Dropbox which the attacker used to exfiltrate data is a sign of poor acceptable use policy. Kevin, a frustrated student with access to campus WI-FI and minimal knowledge of system enumeration and exploitation, was able to successfully compromise the staff workstation. He was able to make an SSH and RDP connection, install a backdoor, spawn a reverse shell and establish persistence on the machine. Due to the combination of EternalBlue vulnerability, lack of network segmentation and unencrypted http traffic made NC3 vulnerable to insider threats such as a frustrated student like Kevin.

If the vulnerabilities aren't patched and addressed, NC3 remains at risk of future attacks such as data breaches and ransomware. This could result in damage to NC3's reputation and loss of students wanting to attend this college. If you follow the recommendations and roadmap I have

discussed NC3 will harden their network infrastructure decreasing the likelihood of future attacks.

Work Cited

Archondakis, A. (2025, June 16). The Top 5 Most Dangerous Cyber Attacks of all Time. Pentest People. <https://www.pentestpeople.com/blog-posts/the-top-5-most-dangerous-cyber-attacks-of-all-time>

BetaFred. (n.d.). Microsoft Security Bulletin MS17-010 - Critical. Microsoft Learn. <https://learn.microsoft.com/en-us/securityupdates/securitybulletins/2017/ms17-010>

Butcher, A. (2023). SMB Signing not required (Windows) Vulnerability. Defense.com Help Centre. <https://help.defense.com/en/articles/6714765-smb-signing-not-required-windows-vulnerability>

Cisco. (2025, July 31). VLAN best practices and security tips for Cisco Business routers. <https://www.cisco.com/c/en/us/support/docs/smb/routers/cisco-rv-series-small-business-routers/1778-tz-VLAN-Best-Practices-and-Security-Tips-for-Cisco-Business-Routers.html>

Cisco. (2026). Secure Shell—Configuring User Authentication Methods. https://www.cisco.com/c/en/us/td/docs/ios-xml/ios/sec_usr_ssh/configuration/xe-3s/asr1000/sec-ssh-cfg-auth.html

Cohen, C. (2023, October 20). What is Port 139? CBT Nuggets. <https://www.cbtnuggets.com/common-ports/what-is-port-139>

Cohen, C. (2024, June 13). What is Port 135? CBT Nuggets. <https://www.cbtnuggets.com/common-ports/what-is-port-135>

GeeksforGeeks. (2025, October 13). TCP 3-Way Handshake Process. <https://www.geeksforgeeks.org/computer-networks/tcp-3-way-handshake-process/>

Invicti. (2026). Reverse Shell. <https://www.invicti.com/learn/reverse-shell>

Jurić, L., Šikić, L., & Novak, M. (2025). Port 5985/5986 – WinRM (Windows Remote Management). PentestPad. <https://www.pentestpad.com/port-exploit/port-59855986-winrm-windows-remote-management>

Jurić, L., Šikić, L., & Novak, M. (2026). Port 5357 – WSDAPI (Web Services for Devices). PentestPad. <https://www.pentestpad.com/port-exploit/port-5357-wsdapi-web-services-for-devices>

Kaplan, C. (2024, July 30). How much time is needed to perform a typical penetration test? HALOCK. <https://www.halock.com/faq/much-time-needed-perform-typical-penetration-test/>

Lee, B. (2025, November 12). Remote desktop protocol TCP port 3389 security risks and vulnerabilities. Specopssoft. <https://specopssoft.com/blog/remote-desktop-protocol-port-3389-vulnerabilities/>

Microsoft. (2017). Microsoft security bulletin MS17-010 – Critical. Microsoft Learn. <https://learn.microsoft.com/en-us/security-updates/securitybulletins/2017/ms17-010>

Paulinbar. (2026). Onboard Windows servers to Microsoft Defender for Endpoint via Group Policy. Microsoft Learn. <https://learn.microsoft.com/en-us/defender-endpoint/configure-endpoints-gp>

Rossouw, J. (2026). Malware of the Day – Encrypted DNS Comparison: Detecting C2 when you can't see the queries. Active Countermeasures. <https://www.activecountermeasures.com/malware-of-the-day-encrypted-dns-comparison-detecting-c2-when-you-cant-see-the-queries/>

SecurityScorecard. (2025, March 20). What is Port 445 (SMB)? Strategies for secure network communication. <https://securityscorecard.com/blog/navigating-the-risks-of-tcp-445-strategies-for-secure-network-communication/>

Appendix: Personal Narrative Thread

On a typical day at Spokane Falls Community College you can go to a lab and do homework on your own personal laptop. If I was the attacker I would go to the lab, start up my laptop and connect to the public Wi-Fi, if staff workstations are on the same network and not separated into VLAN's like they should be, I could establish the SSH connection to the faculty laptop. I then started to browse google on an unencrypted session; I eventually establish an https connection probably by automatic redirect. While still connected to the SSH session on the faculty laptop I access the LMS, a few minutes later I perform the NMAP scan I see that my listener is active on port 1337, pull back up my session on Metasploit and establish the reverse shell connection. At the same time a defender or IT staff member is monitoring the network traffic. They most likely see nothing suspicious until their firewall or SIEM triggers an alert. The alert would most likely come in the form of the port scan followed by an immediate https connection on port 443 with no DNS resolution.

Appendix: Professional Growth Addendum

During this project I developed some new skills regarding my enumeration, exploitation thinking and defensive planning. When you are enumerating a system it's not only important to look at what ports are open but the services running on that port. Also, if you run a port scan and see that there are open ports for port 80 or 8080, they use the http protocol so the traffic will be in plain text. To take advantage of this you can use a sniffer such as Wireshark to analyze the packets and look for session cookies or user login credentials. Another key thing that I learned is that Nessus scans give you a very detailed report of all your system vulnerabilities. This can be used to quickly analyze a system and then you can address the vulnerabilities as needed. As a defender, I will use these tools I learned in this project to run regular tests on a network to ensure it is

hardened the way it should be. Being able to think like a red teamer will give me the ability to know what they are looking for when trying to exploit a system.